

OWASP Top 10:2025 — Study Guide

The OWASP Top 10 is the standard awareness document ranking the most critical web application security risks — and 2025 marks the first full update since 2021 (the 8th edition overall), released at the November 2025 Global AppSec Conference and finalized in January 2026. This ties together almost everything from your last several guides: CWE (each category is a *bucket* of related CWEs), CVE (the data was built from analyzing 175,000+ CVE records), and CVSS (used to weight exploitability/impact in the ranking methodology).

1. What Changed From 2021 → 2025 (Know This Cold)

2021	2025	Change
A01 Broken Access Control	A01 Broken Access Control	Stays #1 — now absorbs SSRF (formerly A10:2021)
A05 Security Misconfiguration	A02 Security Misconfiguration	Jumped from #5 → #2
A06 Vulnerable and Outdated Components	A03 Software Supply Chain Failures	Renamed + expanded scope
A02 Cryptographic Failures	A04 Cryptographic Failures	Dropped #2 → #4
A03 Injection	A05 Injection	Dropped #3 → #5
A04 Insecure Design	A06 Insecure Design	Dropped #4 → #6
A07 Identification and Authentication Failures	A07 Authentication Failures	Same rank, renamed
A08 Software and Data Integrity Failures	A08 Software or Data Integrity Failures	Same rank, minor rename
A09 Security Logging and Monitoring Failures	A09 Security Logging & Alerting Failures	Same rank, renamed to emphasize <i>alerting</i>
A10 Server-Side Request Forgery	Retired — folded into A01	SSRF is now a Broken Access Control sub-issue

2021	2025	Change
—	A10:2025 Mishandling of Exceptional Conditions	New category

Net summary: 2 new/restructured categories (Software Supply Chain Failures, Mishandling of Exceptional Conditions), SSRF consolidated into Broken Access Control, and several categories re-ranked as the underlying CVE/CWE data shifted.

2. A01:2025 — Broken Access Control (#1, unchanged)

What it covers: users acting outside their intended permissions — the largest category by CWE count (40 CWEs), and now includes **SSRF** since server-side request forgery is fundamentally an access-control failure (the server accesses a resource it shouldn't on the attacker's behalf).

Includes concepts you already know:

- IDOR (from your CIA Triad guide's example)
- Privilege escalation
- CORS misconfiguration
- Token manipulation
- SSRF (newly absorbed)

Prevalence: ~3.73% of tested applications had at least one CWE in this category — the highest of any bucket.

CWE examples: CWE-639 (IDOR), CWE-284 (Improper Access Control), CWE-918 (SSRF)
ATT&CK: T1190 (Exploit Public-Facing Application)

3. A02:2025 — Security Misconfiguration (#2, up from #5)

What it covers: insecure defaults, unnecessary features enabled, overly permissive cloud/container/service configs, missing hardening — a category that's grown sharply because modern applications' behavior increasingly lives in configuration rather than code (cloud infra, containers, CI/CD, IaC).

Ties directly to earlier guides:

- Nikto findings (missing security headers, directory listing enabled)
- Default credentials on SNMP/databases (your SNMP/LDAP/RPC and Common Ports guides)
- Exposed `.env` /config files (your Google Dorking guide)

Prevalence: ~3.00% of applications, across 16 CWEs.

4. A03:2025 — Software Supply Chain Failures (new category, expands old A06)

What changed: 2021's "Vulnerable and Outdated Components" was narrowly about using libraries with known CVEs. 2025 broadens this dramatically to cover the *entire* dependency/build/distribution pipeline:

- Compromised package maintainers
- Malicious packages (typosquatting, dependency confusion)
- Tampered CI/CD build processes
- Compromised developer workstations as an entry point

Why it matters so much despite having the fewest CWEs (5) and least test-data presence: it has the **highest average exploit and impact scores** of any category — supply chain compromises are rare in the data but catastrophic when they happen (think SolarWinds, which you already studied in depth via the Kill Chain guide — that's a textbook A03:2025 finding).

Directly connects to your GitHub Dorking guide (Section 15, defending your own repos) and your CVE guide's discussion of CNA-based disclosure.

5. A04:2025 — Cryptographic Failures (#4, down from #2)

What it covers: weak/missing encryption, hardcoded keys, insufficient algorithm strength, cleartext transmission/storage of sensitive data — the "root cause" reframing of what 2021 partially called "Sensitive Data Exposure" (a symptom, not a cause).

Ties to earlier guides:

- Weak SSL/TLS ciphers (your `ssl-enum-ciphers` NSE script)
- Plaintext protocols (FTP/Telnet — your tcpdump guide's cleartext credential demo)
- Hardcoded credentials in source code (your GitHub Dorking guide's `AKIA` / `AIza` prefix searches)

CWE examples: CWE-798 (Hard-coded Credentials), CWE-327 (Broken/Risky Crypto Algorithm)

6. A05:2025 — Injection (#5, down from #3)

What it covers: the classic category — untrusted input reaching a context where it's interpreted as code/commands. Still has the most associated CVEs of any category, spanning high-frequency/low-impact issues (XSS) to low-frequency/high-impact ones (SQL injection).

This is exactly the CWE hierarchy example from your CWE guide — CWE-79 (XSS), CWE-89 (SQLi), CWE-78 (OS Command Injection) all live here, all sharing the same underlying root cause pattern.

Why it dropped in ranking despite still being dangerous: injection is one of the most mature, well-tested categories — better tooling (SAST/DAST, parameterized queries becoming default practice) has reduced real-world prevalence, even though it remains devastating when found.

7. A06:2025 — Insecure Design (#6, down from #4)

What it covers: flaws baked into the *design* of an application, not implementation bugs — missing/ineffective threat modeling, business logic flaws that no amount of secure coding practice can retroactively fix.

Why it dropped: genuine industry improvement — more organizations now do threat modeling and secure-design review upfront, so this category's real-world prevalence has measurably decreased since its introduction in 2021.

Relevant to your OWASP ZAP guide: business logic flaws are exactly what automated scanners (Nikto, Nuclei, Wapiti) *can't* find — this is the category that specifically requires human judgment during manual testing.

8. A07:2025 — Authentication Failures (#7, unchanged, renamed)

What it covers: broken login mechanisms, weak session management, credential stuffing susceptibility, missing MFA — renamed from "Identification and Authentication Failures" to better reflect its 36 CWEs.

Why it held steady rather than worsening: OWASP notes that wider adoption of standardized auth frameworks (OAuth, OIDC, well-tested identity libraries) is measurably reducing custom-auth-implementation bugs — a good example of secure defaults actually working at scale.

Ties to earlier guides: weak/no account lockout policy (your Enum4linux guide's password policy finding), credential stuffing (your Email Enumeration guide's HavelBeenPwned correlation).

9. A08:2025 — Software or Data Integrity Failures (#8, unchanged)

What it covers: failures to verify the integrity of software updates, CI/CD pipelines, or serialized data — insecure deserialization, unsigned/unverified auto-updates, missing code-signing checks.

Distinction from A03 (Supply Chain Failures) worth understanding: A08 is about *trust boundary and integrity verification* at a lower, more technical level (e.g., an application deserializing untrusted data without validation), while A03 is about the broader *ecosystem* compromise (a malicious package entering your build pipeline in the first place). They're related but operate at different layers.

10. A09:2025 — Security Logging & Alerting Failures (#9, unchanged, renamed)

What it covers: insufficient logging of security-relevant events, and — the emphasis of the 2025 rename — insufficient **alerting** on those logs. OWASP explicitly notes: comprehensive logging with no alerting mechanism provides minimal real security value, since nobody acts on an event nobody sees.

Directly relevant to your SOC ambitions: this category is essentially "the reason SOC analysts and SIEM tuning exist" — it's chronically underrepresented in automated testing data (hard to test for programmatically)

and was voted into the list by community survey specifically because practitioners on the ground know it matters even though scanners can't easily measure it.

11. A10:2025 — Mishandling of Exceptional Conditions (NEW category)

What it covers: improper error handling, logic errors, and **fail-open** conditions — scenarios where a system encounters an abnormal state (an exception, an unexpected input, a timeout) and defaults to an *insecure* behavior instead of safely denying access. Contains 24 CWEs.

Why this is genuinely a big addition to understand: a huge class of real-world security bugs isn't "the code executed maliciously" — it's "the code hit an unexpected condition and did the wrong thing by default." A classic example: an authentication check that throws an exception, gets caught by a generic error handler, and the request proceeds as if authenticated because the code defaulted to "allow" instead of "deny" on failure.

This is the practical, security-focused cousin of general software error handling — worth connecting to your NSE/vulnerability scanning guides: fuzzers (Wapiti's approach, ZAP's Fuzzer) are specifically good at surfacing this category, since they intentionally send malformed/unexpected input to see how the app fails.

12. How the 2025 List Was Actually Built (Methodology — Worth Knowing)

This connects directly to your CVE/CWE/CVSS guides:

1. Contributors donated data from 2.8+ million tested applications (Veracode, Semgrep, Sonar, Contrast Security, Bugcrowd, and others)
2. ~175,000 CVE records mapped against 643 unique CWEs from NVD
3. CVSS Exploit + Impact scores extracted and weighted (v2 + v3, not v4 — v4's scoring model doesn't cleanly separate Exploit/Impact the same way)
4. 8 of the 10 categories are chosen from this hard data (prevalence × exploit × impact)
5. The remaining 2 categories are chosen by community survey — because testing data always lags behind what practitioners see happening in the field (this is exactly how Software Supply Chain Failures and Mishandling of Exceptional Conditions earned their spots)

This "8 from data, 2 from community vote" methodology is unchanged from 2021 — a deliberate acknowledgment that automated testing data reflects the past, while practitioner surveys catch emerging risk categories testing tools haven't caught up to yet.

13. OWASP Top 10:2025 ↔ CWE ↔ CVSS ↔ Your Tools — The Full Picture

OWASP 2025 Category	Representative CWEs	Where You'd Find It
A01 Broken Access Control	CWE-639, CWE-918 (SSRF)	ZAP manual testing, IDOR hunting
A02 Security Misconfiguration	CWE-16, CWE-1188	Nikto, Nessus/OpenVAS
A03 Software Supply Chain Failures	CWE-1357, CWE-829	GitLeaks, dependency scanning
A04 Cryptographic Failures	CWE-327, CWE-798	<code>ssl-enum-ciphers</code> NSE, tcpdump cleartext demo
A05 Injection	CWE-89, CWE-79, CWE-78	Wapiti, Nuclei, manual SQLi testing
A06 Insecure Design	CWE-841, CWE-657	Manual/logic testing only
A07 Authentication Failures	CWE-287, CWE-307	Enum4linux password policy checks
A08 Software/Data Integrity Failures	CWE-502, CWE-345	Code review, CI/CD pipeline audit
A09 Logging & Alerting Failures	CWE-778, CWE-223	SIEM/SOC tooling, not a scanner finding
A10 Mishandling of Exceptional Conditions	CWE-755, CWE-390	Fuzzing (ZAP Fuzzer, Wapiti)

14. Kill Chain / ATT&CK Mapping

Category	ATT&CK Relevance
A01, A05, A06	T1190 (Exploit Public-Facing Application)
A03	T1195 (Supply Chain Compromise) — the exact technique behind SolarWinds from your Kill Chain guide

Category	ATT&CK Relevance
A04	T1552 (Unsecured Credentials), T1040 (Network Sniffing)
A09	Maps to detection <i>gaps</i> across nearly every ATT&CK tactic — poor logging is why many techniques go undetected

Quick Reference Cheat Sheet

A01:2025 Broken Access Control (was #1, now includes SSRF)
 A02:2025 Security Misconfiguration (#5 → #2)
 A03:2025 Software Supply Chain Failures (NEW, expands old "Vulnerable Components")
 A04:2025 Cryptographic Failures (#2 → #4)
 A05:2025 Injection (#3 → #5)
 A06:2025 Insecure Design (#4 → #6)
 A07:2025 Authentication Failures (#7, renamed)
 A08:2025 Software or Data Integrity Failures (#8, unchanged)
 A09:2025 Security Logging & Alerting Failures (#9, renamed for "alerting")
 A10:2025 Mishandling of Exceptional Conditions (NEW)

Retired from 2021: A10 Server-Side Request Forgery → absorbed into A01